

ERP/1: Авторизація

Технічні вимоги

до системи керування цифровими ідентичностями,
сертифікатами та політиками безпеки

Зміст

Зміст

Анотація

ERP/1: Служба ідентифікації та авторизації (Identity and Authorization Service — IAS) є центральним керуючим компонентом безпеки Zencrypted-середовища на базі Erlang/OTP. Поточна реалізація веде стійкий реєстр доменних об'єктів у KVS/Mnesia, підтримує граф зв'язків User–Device–Certificate–Security Profile–VPN Service, валідацію CSR та X.509, покроковий провіщення пристрою, доставку бажаного стану до VPN через Erlang RPC, ревізії, аудит доставки, реконсиляцію та відновлення після збоїв. Інтеграція з СА у поточній версії містить перехідний CMP/OpenSSL шлях; цільовою є єдина HTTP-взаємодія з СА без залежності IAS runtime від локального OpenSSL. Вимоги щодо BPE/BPMN, EST/CMC, CRL/OCSP, КСЗІ, КЕП та національних криптографічних алгоритмів у цьому документі позначаються окремо як цільові або комплаєнс-вимоги і не трактуються як уже реалізовані функції.

1. Умовні скорочення та визначення

Термін / Скорочення	Значення
IAS	Identity and Authorization Service
CA	Certificate Authority
VPN	Virtual Private Network
PKI	Public Key Infrastructure
CSR	Certificate Signing Request
CMP	Certificate Management Protocol (RFC 4210)
EST	Enrollment over Secure Transport (RFC 7030)
CMC	Certificate Management over CMS (RFC 5272)
BPE	Business Process Engine
BPMN	Business Process Model and Notation
KVS	Key-Value Storage
ABAC	Attribute-Based Access Control
FSM	Finite State Machine
OTP	Open Telecom Platform

2. Статуси вимог і тверджень

Щоб не змішувати фактичну реалізацію, план розвитку та нормативні наміри, у документі використовуються такі статуси:

Статус	Зміст
Implemented	Підтверджено поточним кодом і тестами IAS.
Partial	Реалізовано частково або лише для конкретного доменного сценарію.
Target	Цільова архітектура або функція наступної ітерації.
Compliance	Нормативна, сертифікаційна або організаційна вимога; не є доказом реалізації.

3. Загальні відомості

3.1. Призначення

IAS централізує керування цифровими ідентичностями, пристроями, сертифікатами, профілями безпеки, VPN-сервісами та зв'язками між ними. IAS є джерелом бажаного стану для керованих VPN-конфігурацій і координує провіженінг, але не бере участі у пересиланні VPN-трафіку.

3.2. Поточний функціональний контур

- Implemented: стійке доменне сховище KVS/Mnesia та версіоновані записи.
- Implemented: граф User–Device–Certificate–Security Profile–VPN Service.

- Implemented: OVPN preview/import, CSR/X.509 validation, certificate lineage та trust evaluation у межах поточного IAS/VPN домену.
- Implemented: device-bound provisioning wizard з перевітками переходів, readiness, remediation та відновленням draft.
- Implemented: IAS → VPN Erlang RPC, канонічні команди, ревізії, digest, idempotence, delivery audit і stale-revision protection.
- Implemented: reconciliation, orphan detection, recovery/decommission та restart recovery.
- Partial: CA enrollment; поточний CMP/OpenSSL шлях є перехідним і підлягає заміні на HTTP adapter.
- Target: виконання оркестрації повного lifecycle через `synrc/bpmn/BPE`.

3.3. Нормативна рамка

Застосовні закони, ДСТУ, ISO/IEC/IEEE, NIST та RFC розглядаються як джерела вимог і критеріїв аудиту. Факт згадки стандарту не означає, що сертифікація, атестація або повна технічна відповідність уже завершені.

4. Архітектурні межі

4.1. IAS і CA

- AS IS / Partial: IAS містить CMP enrollment adapter, який запускає локальний OpenSSL CLI і звертається до CA CMP endpoint.
- Target: IAS передає CSR та контекст випуску до CA через єдиний HTTP-контракт і отримує випущений сертифікат або структуровану помилку.
- Приватний ключ пристрою не повинен передаватися до IAS або CA.
- EST і CMC не входять до поточної реалізації IAS і можуть розглядатися лише як майбутні адаптери.

4.2. IAS і VPN

- IAS є джерелом бажаного стану керованих VPN peers і сервісів.
- Доставка виконується через distributed Erlang RPC канонічними командами з ревізією та digest.
- VPN застосовує команди і зберігає власний durable runtime state.
- IAS веде delivery audit, pending/applied стан, виявляє stale revisions та відновлює доставку після restart або reconnect.
- Reconciliation порівнює authoritative IAS state з runtime snapshot VPN і формує інциденти та дії recovery/decommission.

4.3. Веб-інтерфейс і сховище

- Browser ↔ IAS: N2O/NITRO/Cowboy.
- IAS persistence: KVS/Mnesia через доменні store-модулі.
- `ias_demo_store` використовується як фасад/проекція для UI та демо-сценаріїв і не визначає окрему продуктивну БД.

5. Функціональні вимоги

5.1. Доменна модель

IAS повинен підтримувати щонайменше такі класи об'єктів:

- User, Device, Certificate, SecurityProfile, SecurityPolicy, VPNService;
- CertificateEnrollment і CertificateVerification;
- ProvisioningTransaction, delivery state та delivery audit;
- Relationship graph між користувачами, пристроями, сертифікатами, профілями та сервісами;
- Reconciliation incident, orphan recovery/resolution та decommission barrier.

5.2. Provisioning Wizard lifecycle

Центральний керований процес поточної версії має таку послідовність:

1. Scheme.
2. User.
3. Device.
4. Security Profile & Policy.
5. VPN Service.
6. CA Certificate.
7. Client Certificate.
8. Relationships.
9. Material Readiness.
10. Provisioning.

Поточна реалізація повинна забезпечувати:

- стійкий draft із поточним кроком та вибраними доменними ідентифікаторами;
- guards переходів і заборону руху вперед без необхідних матеріалів;
- автоматичне застосування або ручне виправлення relationship graph;
- перевірку certificate material, trust status та authorization decision;
- створення idempotent provisioning transaction;

- доставку desired state до VPN і відображення результату applied, degraded або failed;
- retry, restart recovery і reconciliation після недоступності VPN.

5.3. OVPN import

OVPN import є допоміжним onboarding-процесом. Система повинна аналізувати конфігурацію, визначати inline CA/certificate/key blocks і параметри підключення, формувати preview та створювати погоджені доменні об'єкти без збереження приватного ключа в IAS.

5.4. CSR та сертифікати

- IAS повинен приймати зовнішній CSR, перевіряти формат, subject та cryptographic consistency доступними засобами OTP.
- IAS повинен зв'язувати випущений сертифікат із CSR, пристроєм, користувачем і профілем безпеки.
- Перевірка validity, issuer, fingerprint, public-key continuity та relationship consistency є обов'язковою.
- CRL/OCSP online validation є Target, доки окрема інтеграція не реалізована і не протестована.

5.5. Авторизація і довіра

Поточна реалізація використовує профілі, політики, атрибути доменних об'єктів, relationship graph і certificate trust для рішень у IAS/VPN сценарії. Це Partial ABAC: універсальний policy language, зовнішні attribute sources, геолокаційні правила та загальний-purpose ABAC engine є Target.

5.6. Provisioning і reconciliation

- Кожна керована зміна повинна мати канонічне представлення, revision і digest.
- Повторна доставка однакової команди повинна бути idempotent.
- Застарілі ревізії не повинні перезаписувати новіший стан.
- Pending і applied heads повинні переживати restart.
- Orphan, fingerprint mismatch, stale revision та unauthorized runtime state повинні відображатися як reconciliation incidents.
- Recovery/decommission дії повинні бути аудованими та захищеними від повторного застосування старого desired state.

6. Нефункціональні вимоги

6.1. Архітектура і надійність

- Реалізація на Erlang/OTP із supervision trees і restart-safe state transitions.
- Authoritative persistence у KVS/Mnesia.
- Явні schema versions та upgrade/migration logic для стійких записів.
- Автоматизовані EUnit і Common Test сценарії для доменних store, provisioning, RPC, reconciliation та recovery.
- Кількісні SLA, capacity і latency targets повинні підтверджуватися окремими benchmark/acceptance tests; до цього вони мають статус Target.

6.2. Безпека

- Приватні ключі користувачів і пристроїв не зберігаються в IAS.
- Секрети, ключовий матеріал і повні credential values не записуються в audit/log output.
- Transport security, node authentication та secret distribution повинні бути визначені для кожного deployment profile.
- КСЗІ ГЗ, CAdES-X Long, ДСТУ 4145-2002, ДСТУ ГОСТ 28147:2009 та at-rest encryption мають статус Compliance/Target, доки немає окремих реалізаційних і атестаційних доказів.

6.3. Логування і аудит

- IAS повинен аудувати lifecycle transitions, issuance/import, authorization decisions, provisioning delivery, reconciliation incidents і recovery actions.
- Audit records повинні мати ідентифікатор об'єкта, revision, результат, причину та часову мітку.
- WORM storage, ELK/Loki export і довгострокове нормативне зберігання є окремими deployment/compliance вимогами, а не автоматичною властивістю поточної реалізації.

6.4. Документація

- Технічні вимоги, техноробочий проєкт і політики повинні використовувати однакові статуси Implemented, Partial, Target і Compliance.
- API/OpenAPI, operator manuals і security profiles створюються відповідно до фактично наявних інтерфейсів.
- BPMN/FSM-діаграми повинні спочатку відображати AS IS lifecycle; BPE execution додається після реалізації відповідної runtime integration.

7. Простежуваність вимог

ID	Вимога	Статус	Доказ / зона реалізації
----	--------	--------	-------------------------

IAS-FR-001	Стійкий реєстр User/Device/Certificate/Profile/VPN Service	Implemented	domain/store modules, KVS/Mnesia tests
IAS-FR-002	CSR і X.509 validation	Implemented	certificate/provisioning modules and tests
IAS-FR-003	CA enrollment через HTTP без OpenSSL у IAS runtime	Target	заміна legacy CMP/OpenSSL adapter
IAS-FR-004	Device-bound provisioning wizard	Implemented	wizard, readiness, relati- onships, authorization
IAS-FR-005	IAS → VPN RPC delivery	Implemented	VPN client/delivery modules and CT suites
IAS-FR-006	Revision, digest, idempotence і stale protection	Implemented	delivery/provisioning state and tests
IAS-FR-007	Reconciliation, orphan recovery і decommission	Implemented	reconciliation/recovery modules and CT suites
IAS-FR-008	BPE/BPMN runtime orchestration	Target	planned migration of wi- zard orchestration
IAS-FR-009	CRL/OCSP, EST і CMC adapters	Target	absent from current runti- me
IAS-NFR-001	КСЗІ ГЗ, КЕП, ДСТУ crypto, at- rest encryption	Compliance	requires separate implementation and evidence

8. Додаток А. Межі поточної версії

Поточна версія не повинна описуватися як така, що вже забезпечує повну універсальну АВАС-платформу, EST/СМС, online CRL/OCSP, загальний REST/OpenAPI surface, TLS 1.3 для всіх каналів, RocksDB/NVMe persistence, WORM audit, гарантовані 100000 пристроїв, 50 мс latency, КСЗІ ГЗ, CAdES-X Long або реалізацію національної криптографії. Такі твердження можуть бути включені лише як Target або Compliance з окремими acceptance criteria.

9. Додаток Б. Цільова послідовність роз- ВИТКУ

1. Синхронізувати `ias.tex` і `ias_pro.tex` з поточним кодом.
2. Замінити server-side OpenSSL/CMP у IAS на канонічний HTTP adapter до CA.
3. Прогнати і стабілізувати повний provisioning wizard lifecycle.
4. Зафіксувати AS IS FSM/BPMN для реального lifecycle.
5. Поетапно перенести orchestration на `synrc/bpmn/BPE`, зберігаючи доменні service modules і тестовану поведінку.
6. Повторно синхронізувати технічні вимоги, техноробочий проєкт і security profiles.